

LokiBot Malware Report

LokiBot — Malware Analysis Report

Published: 2026-06-01 | TLP: CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

1. Executive Summary

LokiBot is a widely distributed Windows information stealer first reported around 2015-2016 and still active in current public sandbox telemetry. ANY.RUN's current tracker ranked it fifth by recent task volume, while MITRE ATT&CK tracks LokiBot as S0447. LokiBot steals usernames, passwords, cryptocurrency wallet data, and other credentials, and can create a backdoor for additional payload deployment.

The highest business risk is credential theft followed by follow-on access. A LokiBot finding should trigger credential resets, session/token invalidation, endpoint isolation, and hunting for secondary payloads.

2. Sample Metadata

Field	Assessment
Family	LokiBot / Lokibot
Type	Information stealer / backdoor-capable malware
Platform	Windows; historical Android targeting also documented by CISA/Check Point
First reported	MITRE lists first reported in 2015
Current ranking	#5 on ANY.RUN current tracker; 198 tasks in last seven days shown
Common delivery	Phishing email, malicious websites, text/private messages, installers, scripts
Confidence	High for behavior; medium for current campaign IOCs

3. Source Review & Confidence

Claim	Source	Date	Confidence	Notes
LokiBot is a widely distributed information stealer that steals passwords, wallets, and credentials.	MITRE ATT&CK S0447	Last modified 2025-04-25	High	ATT&CK software entry.
LokiBot can create a backdoor to install additional payloads.	MITRE ATT&CK S0447	Last modified 2025-04-25	High	Capability statement.
CISA observed increased LokiBot use and documented delivery through email, malicious websites, text, and private messages.	CISA AA20-266A	2020-09-22	High historically	Still useful for delivery and mitigations.

Claim	Source	Date	Confidence	Notes
Check Point describes LokiBot as Windows/Android infostealing malware distributed via phishing, malicious websites, SMS, and messaging platforms.	Check Point LokiBot overview	Accessed 2026-06-01	Medium	Vendor overview.
ANY.RUN tracker shows LokiBot in current top five public task activity.	ANY.RUN Malware Trends Tracker	Accessed 2026-06-01	High for tracker context	Current ranking source.

3.1 Expanded Source Matrix

Source	Contribution	Confidence
ANY.RUN tracker and LokiBot page	Current ranking and sandbox family context.	High
MITRE ATT&CK S0447	Technique mapping and long-term family model.	High
CISA AA20-266A	Government advisory, delivery channels, mitigations, and historical increase in use.	High historically
Check Point LokiBot overview	Family overview, Windows/Android context, detection/protection framing.	Medium / High
Fortinet LokiBot analysis	Historical technical behavior and infostealer framing.	Medium / High
ANY.RUN Malware Trends Report 2025	Commodity infostealer/RAT context.	High

3.2 Evidence Ledger

Claim	Evidence	Confidence	Analyst Note
LokiBot is a credential and wallet stealer with backdoor capability.	MITRE S0447.	High	Core behavior.
LokiBot has been distributed through email, malicious sites, SMS, and private messages.	CISA AA20-266A and Check Point.	High historically	Delivery channels still align with current commodity malware.
LokiBot remains active despite being an older family.	ANY.RUN current tracker.	High for public sandbox activity	Current task volume does not equal global prevalence.

Claim	Evidence	Confidence	Analyst Note
LokiBot response should include credential reset and secondary-payload hunting.	Capability assessment from MITRE/CISA.	High	Backdoor capability increases risk.

4. Payload Variants and Delivery

LokiBot has persisted because it is cheap, distributed through common social-engineering channels, and focused on credential theft. Historical campaigns include phishing, malicious documents, script chains, Windows Installer abuse, malicious websites, SMS/private-message lures, and commodity loader paths. Campaigns can vary significantly by operator.

4.1 Ecosystem and Longevity Notes

LokiBot is older than many current stealers, but it remains relevant because commodity malware does not need novelty to cause harm. Its value to operators is straightforward credential theft and potential secondary access. Organizations should avoid treating older malware as low-risk merely because it is well documented.

The family also demonstrates why historical advisories remain useful. CISA's 2020 advisory is not current campaign telemetry, but its delivery-channel and mitigation guidance still maps cleanly to current infostealer operations: social engineering, malicious links, credential theft, and follow-on access.

5. Infection Chain Analysis

1. User opens malicious file/link or executes a staged installer/script.
2. LokiBot payload runs and may execute PowerShell, cmd, VBS, or macro/script components.
3. Malware profiles system and collects credentials, wallet data, browser data, and other sensitive artifacts.
4. Persistence or backdoor capability may be established.
5. Data is exfiltrated via HTTP C2.
6. Operator may install additional payloads.

6. Technical Analysis

Important behaviors:

- Credential theft from browsers and applications.
- Cryptocurrency wallet theft.
- HTTP C2 communication.
- Command/script interpreter use in some campaigns.
- UAC bypass and persistence behaviors documented by ATT&CK.

- Backdoor capability for secondary payload installation.

6.1 Static Analysis Expectations

For LokiBot samples, review:

- PE metadata, packer, import table, and string obfuscation.
- Browser, wallet, FTP, email, and application credential target strings.
- HTTP C2 endpoint paths, user-agent strings, campaign IDs, and encoded parameters.
- Persistence and UAC-bypass indicators.
- Loader relationship and any secondary payload URLs.
- Android-targeting artifacts only when analyzing mobile-specific samples.

6.2 Dynamic Analysis Expectations

Collect:

- Initial access vector: email, site, SMS/private message, installer, or script.
- Parent process chain and command lines.
- Credential-store, wallet, and app-data file access.
- HTTP C2 traffic and POST body metadata where legally and safely collectable.
- Persistence and backdoor artifacts.
- Additional payload drops or ingress tool transfer events.

7. Indicators of Compromise

7.1 Indicator Summary

Indicator Class	Count	Confidence	Recommended Use
Hashes	Sample-specific	High	Exact-match sweep from sandbox/intel sources.
Domains/IPs	Campaign-specific	Medium	Hunt and enrich.
Host indicators	Behavioral	High	Primary detection value.
Delivery artifacts	Phishing docs/scripts/installers	Medium	Email and endpoint hunting.

7.2 Host Indicators

Type	Indicator	Confidence	Notes
Process	Script interpreter or installer spawning suspicious executable	High	Delivery chain.
File access	Browser credentials, wallet files, local credential artifacts	High	Core behavior.

Type	Indicator	Confidence	Notes
Network	HTTP POST/beacon from unknown user-profile process	Medium	Correlate with process.
Persistence	Autorun or backdoor loader artifacts	Medium / High	Depends on variant.

7.3 IOC Usage Guidance

LokiBot IOCs are highly campaign-specific and age quickly. Prioritize behavioral controls and collect fresh hashes/domains from sandbox detonations, email gateways, EDR, MalwareBazaar, ThreatFox, and URLhaus during active incidents.

8. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1204.002	User Execution: Malicious File	Common phishing/file execution.
T1059.001	PowerShell	Documented command use.
T1059.003	Windows Command Shell	Batch/cmd execution.
T1059.005	Visual Basic	VBS/XLS macro execution.
T1548.002	Bypass User Account Control	ATT&CK-documented behavior.
T1071.001	Web Protocols	HTTP C2.
T1555	Credentials from Password Stores	Credential theft.
T1105	Ingress Tool Transfer	Backdoor/additional payload capability.

9. Detection Engineering

Sigma - LokiBot-Like Script Chain To Credential Theft

```

title: Script Or Installer Chain Launching Suspicious Credential Stealer
id: 52ae839f-e73d-4519-a759-lokibot-0001
status: experimental
description: Detects suspicious script or installer parent processes launching user-profile executables, a common pattern
references:
  - https://attack.mitre.org/software/S0447/
  - https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-266a
author: Lost Boys Cyber
date: 2026-06-01
tags:
  - attack.execution
  - attack.t1204.002
  - attack.credential_access
  - attack.t1555
logsource:
  product: windows
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith:
      - '\wscript.exe'
      - '\cscript.exe'

```

```
- '\powershell.exe'
- '\cmd.exe'
- '\msiexec.exe'
- '\winword.exe'
- '\excel.exe'
selection_child:
  Image|contains:
    - '\AppData\'
    - '\Temp\'
    - '\Users\Public\'
  condition: selection_parent and selection_child
falsepositives:
- Legitimate installers and enterprise scripts; tune by signer, deployment tools, and parent command line.
level: high
```

KQL Hunt

```
DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("wscript.exe","cscript.exe","powershell.exe","cmd.exe","msiexec.exe","winword.exe")
| where FolderPath has_any ("\\AppData\\", "\\Temp\\", "\\Users\\Public\\")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, ProcessCommandLine, FileName, FolderPath, SHA256
```

YARA - LokiBot-Like Credential Stealer

```
rule MAL_Win_LokiBot_Like_Credential_Stealer {
  meta:
    author = "Lost Boys Cyber"
    date = "2026-06-01"
    description = "Generic hunt for LokiBot-like credential and wallet theft strings"
  strings:
    $c1 = "Login Data" ascii wide
    $c2 = "wallet.dat" ascii wide nocase
    $c3 = "password" ascii wide nocase
    $n1 = "Mozilla" ascii wide
    $n2 = "POST" ascii wide
  condition:
    uint16(0) == 0x5A4D and 4 of them
}
```

10. Threat Hunting

Hypothesis: If LokiBot is active, a script/installer or phishing child process will access browser/wallet credential artifacts and communicate over HTTP to suspicious infrastructure.

Hunts:

- Office/script/installer parent processes launching unknown executables.
- Unknown executables accessing browser credential files.
- HTTP POST traffic from new user-profile executables.
- Newly created autoruns after phishing email delivery.
- Secondary payloads after initial infostealer execution.

10.1 Additional Hunt Queries

KQL:

```
DeviceFileEvents
| where Timestamp > ago(14d)
| where FolderPath has_any ("Login Data", "Cookies", "wallet.dat", "FileZilla", "Thunderbird", "Outlook")
| where InitiatingProcessFolderPath has_any ("\\AppData\\", "\\Temp\\", "\\Users\\Public\\")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, InitiatingProcessFolderPath, FolderPath
```

SPL:

```
index=endpoint ("Login Data" OR "Cookies" OR "wallet.dat" OR "FileZilla" OR "Thunderbird" OR "Outlook")
(process_path="*\\AppData\\*" OR process_path="*\\Temp\\*" OR process_path="*\\Users\\Public\\*")
| stats earliest(_time) latest(_time) values(file_path) by host user process_name process_path
```

11. Triage and Incident Response

1. Isolate endpoint.
2. Capture process tree, command lines, autoruns, network connections, and credential-access telemetry.
3. Reset user credentials and invalidate sessions/tokens.
4. Inspect cryptocurrency wallet exposure where relevant.
5. Hunt for backdoor persistence and secondary payloads.
6. Review email gateway logs for related phishing distribution.

11.1 Credential Exposure Model

Exposure	Defensive Action
Browser passwords	Reset affected accounts, prefer password-manager rotation.
Session cookies	Revoke sessions and refresh tokens; monitor impossible travel and new devices.
Wallet artifacts	Move funds from exposed wallets after clean-room recovery.
Email credentials	Review forwarding rules, OAuth grants, sent items, and mailbox audit logs.
Backdoor capability	Hunt for secondary payloads and persistence beyond the first binary.

12. Validation and Emulation

Validate process-chain detections using benign Office/script-to-executable simulations and controlled browser credential file-read testing. Do not use live LokiBot outside a properly isolated malware lab.

13. Recommendations

Priority	Owner	Timeline	Action
Critical	SOC / IR	24 hours	Treat confirmed LokiBot as credential compromise and initiate reset/token revocation.
High	Email Security	7 days	Strengthen detonation of attachments, scripts, and installer files.
High	Endpoint Engineering	7 days	Alert on script/Office/installer child processes executing from user-writable paths.
Medium	Threat Intel	30 days	Refresh LokiBot IOCs from current sandbox and abuse.ch sources during active campaigns.

14. References and Refresh Notes

- ANY.RUN Malware Trends Tracker: <https://anyrun.de/malware-trends/>
- ANY.RUN LokiBot overview: <https://any.run/malware-trends/lokibot/>
- MITRE ATT&CK LokiBot S0447: <https://attack.mitre.org/software/S0447/>
- CISA LokiBot advisory AA20-266A:
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-266a>
- Check Point LokiBot overview:
<https://www.checkpoint.com/cyber-hub/threat-prevention/what-is-malware/lokibot-malware/>
- Fortinet LokiBot infostealer analysis reference from CISA advisory:
<https://www.fortinet.com/blog/threat-research/newly-discovered-infostealer-attack-uses-lokibot>
- ANY.RUN Malware Trends Report 2025: <https://any.run/cybersecurity-blog/malware-trends-2025/>

14.1 Intelligence Gaps

- Public LokiBot documentation is strong historically but less campaign-specific for 2026 than newer stealers.
- Current infrastructure should be collected from fresh sandbox submissions and internal telemetry.
- Android LokiBot behavior should not be mixed into Windows detections without sample confirmation.
- Older family names may be overused by AV labels; confirm with behavior and config.